ZAP by Checkmarx Scanning Report

Generated with ZAP on dim. 19 avr. 2026, at 22:39:17

ZAP Version: 2.15.0

ZAP by Checkmarx

Contents

- About this report
  - Report parameters
- Summaries
  - Alert counts by risk and confidence
  - Alert counts by site and risk
  - Alert counts by alert type
- Alerts
  - Risk=Moyen, Confidence=Haut (4)
  - Risk=Moyen, Confidence=Moyen (1)
  - Risk=Moyen, Confidence=Faible (1)
  - Risk=Faible, Confidence=Haut (2)
  - Risk=Faible, Confidence=Moyen (3)

- Risk=Faible, Confidence=Faible (1)
- Risk=Pour information, Confidence=Haut (1)
- Risk=Pour information, Confidence=Moyen (2)
- Risk=Pour information, Confidence=Faible (2)

- Appendix
  - Alert types

About this report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `https://ga.jspm.io`
- `http://localhost:8090`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `Haut`, `Moyen`, `Faible`, `Pour information`

Excluded: None

Confidence levels

Included: User Confirmed, Haut, Moyen, Faible

Excluded: User Confirmed, Haut, Moyen, Faible, Faux positif

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	Haut	Moyen	Faible	Total
Risk	Haut	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)	0 (0,0 %)
	Moyen	0 (0,0 %)	4 (23,5 %)	1 (5,9 %)	1 (5,9 %)	6 (35,3 %)
	Faible	0 (0,0 %)	2 (11,8 %)	3 (17,6 %)	1 (5,9 %)	6 (35,3 %)
	Pour information	0 (0,0 %)	1 (5,9 %)	2 (11,8 %)	2 (11,8 %)	5 (29,4 %)
	Total	0 (0,0 %)	7 (41,2 %)	6 (35,3 %)	4 (23,5 %)	17 (100%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		Haut (= Haut)	Moyen (>= Moyen)	Faible (>= Faible)	Pour information (>= Pour information)
Site	https://ga.jspm.io	0 (0)	1 (1)	3 (4)	0 (4)
	http://localhost:8090	0 (0)	5 (5)	3 (8)	5 (13)

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Absence de Jetons Anti-CSRF	Moyen	1 (5,9 %)
CSP: Wildcard Directive	Moyen	105 (617,6 %)
CSP: script-src unsafe-inline	Moyen	105 (617,6 %)
Total		17

Alert type	Risk	Count
CSP: style-src unsafe-inline	Moyen	105 (617,6 %)
Mauvaise configuration inter-domaines	Moyen	1 (5,9 %)
ZAP is Out of Date	Moyen	2 (11,8 %)
Big Redirect Detected (Potential Sensitive Information Leak)	Faible	1 (5,9 %)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Faible	162 (952,9 %)
Server Leaks Version Information via "Server" HTTP Response Header Field	Faible	247 (1 452,9 %)
Strict-Transport-Security Header Not Set	Faible	1 (5,9 %)
Timestamp Disclosure - Unix	Faible	2 (11,8 %)
X-Content-Type-Options Header Missing	Faible	1 (5,9 %)
Authentication Request Identified	Pour information	4 (23,5 %)
Cookie faiblement couplé	Pour information	16 (94,1 %)
Information Disclosure - Suspicious Comments	Pour information	19 (111,8 %)
Total		17

Alert type	Risk	Count
Modern Web Application	Pour information	29 (170,6 %)
Session Management Response Identified	Pour information	18 (105,9 %)
Total		17

Alerts

Risk=Moyen, Confidence=Haut (4)

http://localhost:8090 (4)

CSP: Wildcard Directive (1)

▶ GET http://localhost:8090/sitemap.xml

CSP: script-src unsafe-inline (1)

▶ GET http://localhost:8090/robots.txt

CSP: style-src unsafe-inline (1)

▶ GET http://localhost:8090/robots.txt

ZAP is Out of Date (1)

▶ GET http://localhost:8090/robots.txt

Risk=Moyen, Confidence=Moyen (1)

https://ga.jspm.io (1)

Mauvaise configuration inter-domaines (1)

▶ GET https://ga.jspm.io/npm:es-module-shims@1.10.0/dist/es-module-shims.js

Risk=Moyen, Confidence=Faible (1)

http://localhost:8090 (1)

Absence de Jetons Anti-CSRF (1)

▶ POST http://localhost:8090/register

Risk=Faible, Confidence=Haut (2)

https://ga.jspm.io (1)

Strict-Transport-Security Header Not Set (1)

▶ GET https://ga.jspm.io/npm:es-module-shims@1.10.0/dist/es-module-shims.js

http://localhost:8090 (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▶ GET http://localhost:8090/sitemap.xml

Risk=Faible, Confidence=Moyen (3)

https://ga.jspm.io (1)

X-Content-Type-Options Header Missing (1)

▶ GET https://ga.jspm.io/npm:es-module-shims@1.10.0/dist/es-module-shims.js

http://localhost:8090 (2)

Big Redirect Detected (Potential Sensitive Information Leak) (1)

▶ POST http://localhost:8090/reset-password

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

▶ GET http://localhost:8090/sitemap.xml

Risk=Faible, Confidence=Faible (1)

https://ga.jspm.io (1)

Timestamp Disclosure - Unix (1)

▶ GET https://ga.jspm.io/npm:es-module-shims@1.10.0/dist/es-module-shims.js

Risk=Pour information, Confidence=Haut (1)

http://localhost:8090 (1)

Authentication Request Identified (1)

▶ POST http://localhost:8090/login

Risk=Pour information, Confidence=Moyen (2)

http://localhost:8090 (2)

Modern Web Application (1)

▶ GET http://localhost:8090/

Session Management Response Identified (1)

▶ GET http://localhost:8090/

Risk=Pour information, Confidence=Faible (2)

http://localhost:8090 (2)

Cookie faiblement couplé (1)

▶ GET http://localhost:8090/

Information Disclosure - Suspicious Comments (1)

▶ GET http://localhost:8090/assets/js/imagesloaded.pkgd.min.js

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

Absence de Jetons Anti-CSRF

Source	raised by a passive scanner (Absence de Jetons Anti-CSRF)
CWE ID	352

WASC ID	9
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ▪ https://cwe.mitre.org/data/definitions/352.html

CSP: Wildcard Directive

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources

CSP: script-src unsafe-inline

Source	raised by a passive scanner (CSP)
CWE ID	693

WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources

CSP: style-src unsafe-inline

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources

Mauvaise configuration inter-domaines

Source	raised by a passive scanner (Mauvaise configuration inter-domaines)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?id=desc.config.dotnet.html5_overly_permissive_cors_policy

ZAP is Out of Date

Source	raised by a passive scanner (ZAP is Out of Date)
CWE ID	1104
WASC ID	45
Reference	▪ https://www.zaproxy.org/download/

Big Redirect Detected (Potential Sensitive Information Leak)

Source	raised by a passive scanner (Big Redirect Detected (Potential Sensitive Information Leak))
CWE ID	201
WASC ID	13

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))

CWE ID	200
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework ▪ https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	200
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Strict-Transport-Security Header Not Set

Source	raised by a passive scanner (Strict-Transport-Security Header)
CWE ID	319
WASC ID	15

Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html ▪ https://owasp.org/www-community/Security_Headers ▪ https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security ▪ https://caniuse.com/stricttransportsecurity ▪ https://datatracker.ietf.org/doc/html/rfc6797

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	200
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-

developer/compatibility/gg622941(v=vs.85)

- https://owasp.org/www-community/Security_Headers

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)
Reference	- https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Cookie faiblement couplé

Source	raised by a passive scanner (Cookie faiblement couplé)
CWE ID	565
WASC ID	15
Reference	- https://tools.ietf.org/html/rfc6265#section-4.1 - https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html - https://code.google.com/p/browsersec/wiki/Part2#Same-origin_policy_for_cookies

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)

CWE ID	200
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id